

D-SGSI-00: Marco de Referencia Terminológico y Normativo

Universidad Nacional del Centro del Perú (UNCP)

SGSI ISO/IEC 27001:2022

Organización: Universidad Nacional del Centro del Perú (UNCP) **Versión:** 1.0 (Enfoque Semántico y Multi-marco)
Normas Base: ISO/IEC 27000:2018, NIST SP 800-53, MITRE ATT&CK v14

1. Propósito

Establecer el lenguaje común y el mapa normativo que rige el SGSI de la UNCP. Este marco garantiza la interoperabilidad semántica entre los equipos de Auditoría (Cumplimiento), la OTI (Técnicos) y la Alta Dirección (Estratégicos), eliminando ambigüedades en la interpretación de riesgos y controles.

2. Ontología de Seguridad (Relaciones Semánticas)

A diferencia de un glosario lineal, la UNCP adopta una **Ontología Dinámica** donde los términos se relacionan jerárquicamente para facilitar el razonamiento de riesgo:

- **ACTIVO (ISO)** tiene un **VALOR (ISO)** y posee **VULNERABILIDADES (ISO/NIST)**.
- **AMENAZA (ISO)** explota una **VULNERABILIDAD** mediante una **TÉCNICA/TÁCTICA (MITRE)**.
- La explotación resulta en un **INCIDENTE (ISO)** que impacta la **CID (ISO)**.
- Se aplica un **CONTROL (ISO/NIST)** para mitigar el **RIESGO (ISO 31000)**.

3. Diccionario Crítico Interoperable (ISO / NIST / MITRE)

Término (ISO 27000)	Definición Semántica	Correspondencia NIST / MITRE
Activo	Cualquier cosa que tiene valor para la UNCP.	Asset: Enfoque en datos y sistemas críticos.
Riesgo	Efecto de la incertidumbre sobre los objetivos de seguridad.	Risk: Probabilidad x Impacto (ISO 31000).
Amenaza	Causa potencial de un incidente no deseado.	Threat Actor / Campaign: Identificado en MITRE ATT&CK.
Vulnerabilidad	Debilidad de un activo o control que puede ser explotada.	Weakness (CWE) / Vulnerability (CVE).
Control	Medida que modifica el riesgo.	Security Control: NIST SP 800-53 (High/Mod/Low).
Incidente	Evento inesperado que tiene probabilidad de comprometer la CID.	Detection & Response: Alineado a NIST CSF.
Técnica	(Extensión UNCP) Método operativo de ataque.	MITRE Technique: Ejemplo: <i>Phishing (T1566)</i> .

4. Mapa de Referencias Normativas

4.1. Normas Internacionales (Frameworks)

- **ISO/IEC 27001:2022:** Requisitos del Sistema de Gestión.
- **ISO/IEC 27002:2022:** Guía de controles de seguridad.

- **ISO 31000:2018:** Directrices para la gestión de riesgos.
- **NIST Cybersecurity Framework (CSF) 2.0:** Resiliencia y respuesta operativa.

4.2. Normativa Nacional (Perú)

- **Ley N° 29733:** Ley de Protección de Datos Personales y su Reglamento (D.S. 016-2024-JUS).
- **Decreto Legislativo N° 1412:** Ley de Gobierno Digital.
- **MAGERIT v3:** Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información (Sector Público).

5. Procedimiento de Actualización Continua

Para evitar la obsolescencia del marco normativo, el Oficial de Seguridad realizará las siguientes acciones:

1. **Suscripción a Alertas:** Monitoreo mensual de la **Plataforma OBP de ISO** y la **Electropedia de IEC** para detectar cambios en términos técnicos.
2. **Sincronización MITRE/NIST:** Revisión semestral de las actualizaciones de la matriz ATT&CK y el glosario NIST para integrar nuevos vectores de ataque al diccionario de la UNCP.
3. **Mantenimiento de Versiones:** Cualquier cambio en un término crítico será comunicado al Comité de Gobierno Digital y actualizado en el repositorio de Micro-Auditorías (R-SGSI-01).

Este marco es la referencia definitiva para toda la documentación del SGSI-UNCP.